

Secure Network Architecture Report

Name: Solomon

Date: March 15, 2026

Role: Junior Cybersecurity Engineer

Network Segmentation Goals and Access Controls

- **Purpose of this Network Configuration:** To implement a Zero Trust-lite architecture where the Database Subnet is isolated from general traffic, specifically allowing the Finance department to access financial records while preventing unauthorized access from the HR department.
- **Why is network segmentation necessary?** It limits the "blast radius" of a potential breach. If the HR subnet is compromised, the attacker cannot pivot to the Database server because the VyOS router drops that traffic at the gate.
- **Specific Access Controls:** Service-specific filtering was used. We didn't just allow Finance to talk to the DB; we restricted it specifically to **TCP Port 3306** (MySQL).
- **Security Best Practices:** This aligns with **CIS Benchmark 5.1** (Establish Network Segmentation) and **PCI DSS Requirement 1.3**, which mandates restricting traffic between the Cardholder Data Environment (CDE) and other networks.

Access Control Rules and Justification

- **Allowed Traffic:** TCP traffic from 192.168.1.0/24 to 192.168.3.2:3306.
- **Denied Traffic:** All traffic from 192.168.2.0/24 to 192.168.3.0/24.
- **Justification:** The Finance department requires database access for operational duties. The HR department has no business need for MySQL access; therefore, per the **Principle of Least Privilege**, their access is denied.

Firewall Rules and Network Traffic Control

Rule Name	Source Subnet	Destination Subnet	Protocol	P	Action

FIN-DB-ALLOW	192.168.1.0/24	192.168.3.0/24	TCP	3	Accept
HR-DB-DENY	192.168.2.0/24	192.168.3.0/24	TCP	3	Drop

Traffic Validation and Analysis

- **Connectivity Tests:** * Finance to DB: **Successful** (Ping and MySQL handshake).
 - HR to DB: **Failed** (Timeout).
- **Capturing and Analyzing Traffic:** Using **tcpdump**, we observed the 3-way handshake (SYN, SYN-ACK, ACK) between Finance and the DB. When HR attempted a connection, **tcpdump** showed incoming SYN packets but no response from the server, confirming the VyOS firewall was dropping packets silently.

Example Captured Data

Source IP	Destination IP	Protocol	P	Allowed/Blocked
192.168.1.2	192.168.3.2	TCP	3	Allowed
192.168.2.2	192.168.3.2	TCP	3	Blocked

--	--	--	--	--

Reflection on Network Security Implementation

- **Effectiveness:** The segmentation was highly effective. By placing the database on its own subnet (.3.0/24), we forced all traffic through the VyOS inspector.
- **Challenges:** The primary challenge was routing. Without the static routes added via Netplan, the DB-VM didn't know how to "reply" to the Finance-VM, even if the firewall allowed the traffic in.
- **Future Enhancements:** 1. Implement an **Intrusion Detection System (IDS)** like Snort to watch for SQL injection in the allowed Finance traffic.
2. Use **SSH Key authentication** for management and disable password-based logins.
- **Broader Implications:** In real-world environments, this prevents **Ransomware** from spreading laterally across the company. Even if an HR employee clicks a malicious link, the malware cannot reach the critical database.
-